3.5 Etapa 5: Política de Contratação de Terceiros

3.5.1 Introdução

A Política de Contratação de Terceiros da Softeam define diretrizes para auxiliar no processo de contratação, visando assegurar que a seleção, gestão e relacionamento com fornecedores ou prestadores de serviços sejam conduzidas de forma transparente e segura para todas as partes envolvidas.

A abrangência desta Política se estende a todos os colaboradores da Softeam, sua aplicação é obrigatória em todos os processos de contratação de Terceiros.

3.5.2 Objetivos do Plano

O Quadro 24, abaixo, destaca os objetivos principais do Plano de Contratação de Terceiros.

Quadro 24 - Objetivos do Plano de Contratação de Terceiros

Categorias	Descrições
Governança e Conformidade	➢ Garantir que o processo de contratação de terceiros esteja em conformidade com as legislações
Alinhamento Estratégico	➢ Selecionar colaboradores que estejam em sintonia com os valores e objetivos da organização
Riscos e Segurança da Informação	➢ Incluir cláusulas de segurança em contratos ➢ Proteger os dados da organização ➢ Preservar a confidencialidade, integridade e disponibilidade das informações.
Processo de Contratação	➢ Qualidade no processo de contratação de Terceiros ➢ Transparência em todo o processo de recrutamento e seleção.

Fonte: Elaborado pelos autores (2024)

3.5.3 Avaliação de Riscos

O Quadro 25, apresentado abaixo, cita a avaliação de riscos do plano de contratação de terceiros.

Quadro 25 - Avaliação de Riscos do Plano de Contratação de Terceiros

Classificações de ameaças internas			
Categorias		**Descrições**	
Funcionário mal-intencionado (*Malicious Insider*):		"Agentes internos maliciosos geralmente são funcionários atuais insatisfeitos ou ex-funcionários insatisfeitos cujas credenciais de acesso não foram retiradas, que usam seu acesso de maneira intencional por vingança, ganho financeiro ou ambos. Alguns agentes internos maliciosos "trabalham" para terceiros mal-intencionados, como um hacker, concorrente ou agente de estado-nação.". Fonte IBM, 2024	
Funcionário negligente (Negligent Insider):		"Agentes internos negligentes não têm intenção maliciosa, mas criam ameaças à segurança por meio de ignorância ou descuido". Fonte IBM, 2024	
Agente interno comprometido:		"Agentes internos comprometidos são usuários legítimos cujas credenciais foram roubadas por agentes de ameaças externos". Fonte IBM,2024	
Principais riscos			
Acesso não autorizado a dados:		➢ Acesso não autorizado de terceiros aos ambientes internos ➢ Compartilhamento não autorizado ou roubo de credenciais	
Vazamento de informações:		➢ Exfiltração de dados internos por terceiros mal-intencionados. ➢ Compartilhamento indevido de informações	
Comprometimento de sistemas:		➢ Exploração de vulnerabilidades	
Análise dos Riscos			
Risco	**Probabilidade**	**Impacto**	**Nível de Risco**
Acesso não autorizado a dados:	Alta	Alto	Crítico

Classificações de ameaças internas			
Categorias		**Descrições**	
Funcionário mal-intencionado (*Malicious Insider*):		"Agentes internos maliciosos geralmente são funcionários atuais insatisfeitos ou ex-funcionários insatisfeitos cujas credenciais de acesso não foram retiradas, que usam seu acesso de maneira intencional por vingança, ganho financeiro ou ambos. Alguns agentes internos maliciosos "trabalham" para terceiros mal-intencionados, como um hacker, concorrente ou agente de estado-nação.". Fonte IBM, 2024	
Funcionário negligente (Negligent Insider):		"Agentes internos negligentes não têm intenção maliciosa, mas criam ameaças à segurança por meio de ignorância ou descuido". Fonte IBM, 2024	
Agente interno comprometido:		"Agentes internos comprometidos são usuários legítimos cujas credenciais foram roubadas por agentes de ameaças externos". Fonte IBM,2024	
Principais riscos			
Vazamento de informações	Média	Muito Alto	Crítico
Comprometimento de sistemas:	Alta	Muito Alto	Crítico

Fonte: Elaborado pelos autores (2024)

3.5.4 Critérios de Seleção de Terceiros

O Quadro 26, apresentado abaixo, cita os Critérios de Seleção de Terceiros do plano de contratação de terceiros.

Quadro 26 - Objetivos do Plano de Contratação de Terceiros

Categorias	Descrições
Conflitos de Interesses	Avaliar e identificar possíveis conflitos de interesses no processo de seleção de terceiros.
Aspectos Financeiros	Verificar se o valor cobrado está de acordo com o mercado.
Benefícios Diretos e Indiretos	Identificar se a contratação oferece benefícios.

Categorias	Descrições
Conformidade Legal e Compliance	Assegurar que o terceiro esteja em conformidade legal e com as normas.
Experiência e Reputação	Avaliação e feedback e reputação e presença de mercado.
Capacidade Técnica	Qualificação técnica e recursos disponíveis.

Fonte: Elaborado pelos autores (2024)

3.5.5 Acordos Contratuais

As partes contratadas deverão ter responsabilidade quanto aos dados compartilhados entre elas para realizar a parceria.

Todos os dados devem ser protegidos pela parte terceirizada a menos que devam ser compartilhados com agentes governamentais para cumprimento da lei ou ser divulgados para fins de transparência ou propaganda, e isso couber à parte terceirizada.

A empresa terceirizada compromete-se a manter os mesmos requisitos de segurança adotados pela Softeam, a menos que uma situação específica justifique a não adoção ou se não forem aplicáveis em função da diferença de natureza entre as duas empresas.

Além do mais, a empresa contratada deve demonstrar que cumpre normas regulatórias específicas para a função que exerce.

Em caso de violação de dados sofrida pela empresa contratada que esteja relacionada à parceria com a Softeam de qualquer forma, a empresa contratada compromete-se a relatar o incidente de forma imediata e completa.

3.5.6 Avaliação de Segurança

Os processos de avaliação de segurança se dividirão em três tipos: questionários, avaliações da Softeam e apresentação de certificados.

Os questionários, ou entrevistas, serão compostos por uma série de questões que irão avaliar se os processos e normas da empresa estão em harmonia com a política de segurança da Softeam.

A avaliação da Softeam será realizada através de testes e auditorias. Eles vão avaliar se os processos e a estrutura da empresa contratada estão realmente de acordo com as normas

descritas. A apresentação e validação do certificado será realizada quando a avaliação da Softeam não for viável ou quando a apresentação do certificado for suficiente para comprovar aderência às normas.

3.5.7 Monitoramento Contínuo

Após a contratação, a Softeam realizará o monitoramento contínuo das atividades desempenhadas durante o período de vigência do contrato.

Caso o terceiro não atenda às notificações de não conformidade ou ao prazo estabelecido, a Softeam tomará a medida de rescindir o contrato.

3.5.7.1. Política de Homologação e Monitoramento de Terceiros

Consolidar uma política que detalhe os objetivos, ferramentas e processos utilizados para monitorar a conformidade dos terceiros com os requisitos de segurança da Softeam.

3.5.7.2. Relatórios Periódicos

A. **Relatórios de conformidade:** Solicite que os terceiros enviem periodicamente auditorias, certificações ou relatórios como ISO 27001 ou outros padrões aplicáveis.
B. **Análises de desempenho:** Com base na coleta de informações dos relatórios de conformidade, será realizada uma avaliação dos indicadores-chave (KPIs) fornecidos pelos terceiros.

3.5.7.3. Logs

A. **Integração de logs:** Os terceiros deverão compartilhar os logs de atividades críticas em tempo real (ou próximo disso) por meio da integração deste fluxo com as ferramentas de monitoramento centralizado utilizadas pela Softeam.
B. **Automação:** Deverá ser realizada a implantação de serviços de automação que permitam identificar padrões anômalos nos logs, como falhas de autenticação, transferências de dados não autorizadas ou picos de acessos incomuns.

3.5.7.4. Revisões de Conformidade

A. **Revisões periódicas:** Realize avaliações trimestrais ou semestrais para verificar se os requisitos de segurança definidos em contrato ainda estão aderentes ao apetite de risco da Softeam.
B. **Checklists de conformidade:** Utilize listas de verificação para assegurar que os controles de segurança estão implementados e funcionando conforme o esperado.

3.5.7.5. Auditoria

A. **Auditorias intern**as: Realize auditorias anuais com foco em avaliar o gerenciamento de dados, acesso a sistemas, e conformidade com os requisitos de segurança homologados pelo time de segurança da informação da Softeam e conformidade com as leis vigentes (LGPD).
B. **Testes de intrusão:** Os terceiros deverão apresentar, periodicamente, relatórios de pentest em seus ambientes, trazendo visibilidade do cenário atual do terceiro em relação a conformidade para com os requisitos de segurança da Softeam, bem como as medidas de correção aplicadas, se necessário.

3.5.8 Gestão de Incidentes

3.5.8.1. Plano de Resposta a Incidentes

A. Consolidação do PRI com base nas diretrizes do NIST e correlacionando situações que envolvam terceiros:
B. Etapas de contenção, erradicação e recuperação de incidentes.
C. Comunicação com os terceiros envolvidos e outros stakeholders internos e externos.
D. Requisitos de documentação e auditoria pós-incidente.

3.5.8.2. Papéis e Responsabilidades

A. **Responsável Interno:** O um ponto focal Softeam será o DPO para coordenar com os terceiros em caso de incidente, priorizando intercorrências de vazamentos de dados e possíveis sanções legais perante a LGPD.
B. **Responsáveis externos:** O fornecedor deverá definir um profissional no qual será responsável pela comunicação e ação durante o incidente.

3.5.8.3. Notificação do incidente

A. **SLA da notificação:** O prazo mínimo esperado para a notificação de incidentes deverá ser calculado com base na criticidade dos eventos, para incidentes críticos a notificação deverá ocorrer em no máximo 24 horas.
B. **Canais de comunicação:** Criação e manutenção canais seguros para troca de informações sobre incidentes (ex.: mensagens criptografadas em plataformas segregadas dos meios de comunicação oficiais da Softeam).

3.5.8.4. Resposta ao Incidente

A. **Identificação:** Procedimento estruturado com foco em determinar se o incidente impacta diretamente os dados ou sistemas Softeam.
B. **Contenção:** Procedimento estruturado com foco em reduzir a propagação do incidente, bem como os seus eventuais prejuízos aos sistemas Softeam.
C. **Análise de impacto:** Procedimento estruturado com foco em avaliar o escopo e a gravidade do incidente para decidir os próximos passos, caso haja impacto direto nos sistemas Softeam.
D. **Ação corretiva:** Procedimento estruturado em alinhamento com o terceiro para a correção da intercorrência, bem como a validação se a mitigação foi efetiva para resolver o incidente.

3.5.8.5. Comunicação pós Incidente

A. **Notificações legais:** Fluxo estruturado para realizar a comunicação do incidente e determinar quais partes precisam ser notificadas publicamente (clientes, autoridades legais, etc.) com base na LGPD.

B. **Relatórios pós-incidente:** Deverá ser consolidado um relatório detalhado contendo as seguintes diretivas:
    a. Causa raiz do incidente.
    b. Ações corretivas realizadas.
    c. Medidas preventivas adotadas.

3.5.9 Encerramento do Contrato

Para garantir um encerramento claro do contrato com terceiros, especialmente em relação a dados e acesso, é essencial assegurar o cumprimento de todas as obrigações contratuais, a segurança no tratamento dos dados e a exoneração de responsabilidades entre as partes envolvidas.

3.5.9.1 Notificação de Encerramento

- **Prazos**: Defina um prazo mínimo para a notificação do encerramento do contrato (exemplo: 30 ou 60 dias).
- **Forma de Notificação**: A notificação deve ser feita por escrito, via e-mail ou carta registrada, informando a data efetiva do término do contrato.

3.5.9.2 Devolução e Exclusão de Dados

- **Devolução de Dados**: O terceiro é responsável por devolver todos os dados do contrato tanto em formato físico ou digital
    - **Formato e Prazo**: Indique o formato desejado para a devolução (como por exemplo, em formato digital ou em formatos específicos) e também o prazo para devolução (por exemplo, 10 dias após ser notificado).
    - **Segurança e confidencialidade**: É responsabilidade do terceiro garantir que os dados sejam devolvidos de maneira segura e que medidas adequadas de proteção sejam tomadas durante o processo.

- **Exclusão de Dados**: Após a devolução ou término de uso, todas as informações confidenciais ou sensíveis devem ser excluídas de forma irreversível, seja de sistemas, backups ou dispositivos.
    - **Certificado de Exclusão**: Solicite que o terceiro forneça um certificado de que os dados foram excluídos de forma adequada, conforme as regulamentações de proteção de dados, como a LGPD (Lei Geral de Proteção de Dados) ou GDPR (Regulamento Geral de Proteção de Dados).

3.5.9.3 Encerramento de Acessos

- **Revogação de Acessos**: Todos os acessos de sistemas, plataformas, e redes fornecidos ao terceiro devem ser imediatamente revogados no momento do encerramento do contrato.
    - **Acessos Físicos e Virtuais**: Inclui todos os tipos de acessos, como contas de e-mail, redes internas, plataformas de software, sistemas financeiros e físicos.
    - **Documentação de Revogação**: Solicite uma lista de todos os acessos revogados e um relatório de atividades realizadas, caso necessário para auditorias.

3.5.10 Revisão e Atualização

O **Plano de Contratação e Acompanhamento de Terceiros** deve ser periodicamente revisado e atualizado para garantir que ele continue relevante e eficaz, especialmente no que diz respeito à **segurança da informação**. Isso é crucial para mitigar riscos, adaptar-se a novas regulamentações e atender às mudanças no ambiente de negócios e nas tecnologias utilizadas.

3.5.10.1 Definição de Frequência e Responsáveis

- **Periodicidade de Revisão**: A recomendação é realizar uma **revisão anual** completa, com atualizações pontuais sempre que houver mudanças significativas (como novas regulamentações, incidentes de segurança ou mudança de tecnologia).

- **Responsáveis pela Revisão**: Designar uma equipe responsável pela revisão e atualização, composta por profissionais de **segurança da informação**, **jurídico**, **área de compliance**, **TI**, **gestão de contratos** e outras áreas relevantes.
    - **Equipe principal**: Gestores de Segurança da Informação (CISO), Coordenadores de Compliance e Gerentes de TI.
    - **Consultores externos**: Quando necessário, contar com consultoria externa especializada em segurança da informação ou em regulamentações como LGPD.

3.5.10.2 Monitoramento Contínuo e Melhoria Contínua

- **Medição Contínua de Eficácia**: O plano de segurança deve ser continuamente monitorado para garantir que seja eficaz, com melhorias sendo implementadas conforme necessário.
- **Inovações e Melhorias**: Avaliar continuamente as melhores práticas e inovações em segurança da informação para garantir que o plano esteja sempre alinhado às melhores práticas do setor.
- **Ciclo de Melhoria Contínua**: O processo de revisão deve seguir o ciclo de **PDCA (Plan-Do-Check-Act)**, garantindo que as atualizações sejam feitas de forma estruturada e alinhada com os objetivos de segurança da organização.

3.5.10.3 Relatórios de Atualizações

- **Relatórios Regulares**: A cada revisão, gerar um relatório detalhado sobre as modificações realizadas no plano e os motivos das atualizações. Isso pode ser útil para auditorias e revisões de conformidade, bem como para manter a alta gestão informada.

4. CONSIDERAÇÕES FINAIS

Os resultados obtidos no projeto demonstram uma implementação bem-sucedida da segurança da informação no contexto empresarial.

Os desafios enfrentados no desenvolvimento deste projeto foram significativos, dada a complexidade de simular um ambiente empresarial realista com setores distintos, a simulação abrangeu a elaboração dos seguintes documentos do plano de Master Data Management (MDM), Plano Detecção, Mitigação e Acompanhamento de Ameaças, plano de continuidade de serviços de TIC (PCTIC), Plano de Segurança de Recursos em Tecnologia da Informação. Política de Contratação de Terceiros

Essas iniciativas estão alinhadas com o objetivo geral do projeto, que é fornecer uma visão detalhada da aplicação da segurança da informação no contexto empresarial, Através da simulação bem-sucedida e das estratégias implementadas, a equipe demonstrou capacidade de enfrentar desafios reais no mercado de trabalho